

Findings

What the scan found in the tenant.

Needs: ✓ scan complete · ✓ baseline loaded

Based on the scan from this minute · Aug 28, 2026, 12:00 PM. [Re-scan](#) · Baseline: synthetic baseline Sign-in evidence covers the last 30 days; re-scan once the scan is more than 7 days old.

1 goal in this baseline, 16 apply to this tenant. The rest are under Details with the reason each one does not apply.

Summary

IAMAI compared Contoso Pty Ltd's 1 enabled Conditional Access policy with synthetic baseline (1 policy), matching each policy on what it does. 2 of 16 security goals are in place; 1 partly (a policy covers some of the people, or a weaker control than the goal needs), 13 missing.

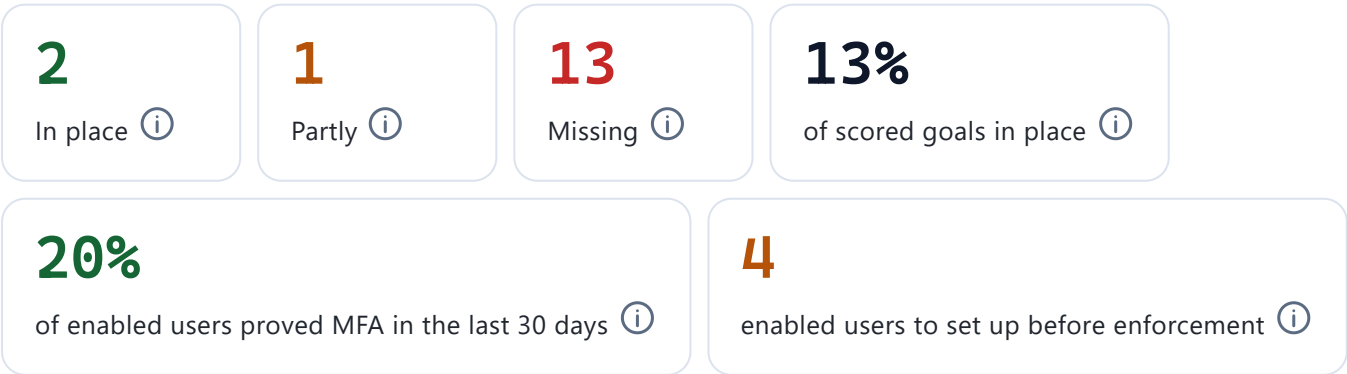
5 users in the directory, 4 active in the last 90 days. 1 of 5 enabled users (20%) proved MFA in the last 30 days. 1 user has no MFA method and 3 users are registered but unproven: 4 users to set up before enforcement.

Already in place: every user satisfies MFA on every app, guests satisfy MFA.

Fix first: security-info registration requires a trusted context; device-code flow blocked; authentication transfer blocked. The Roadmap dates each one, names who it touches, and gives the exact change.

5 goals need a licence tier this tenant does not have; they are listed on the Licensing guide and left out of the score.

i IAMAI inferred no exclusion groups and 1 likely break-glass account from how the policies use them. Confirm them in [Setup](#) to remove the hedging.



Here's what's working

Identity

- ▼ **In place** **Every user satisfies MFA on every app.** Delivered by *CA001 - Require MFA for all users*, with 1 break-glass account excluded. Value 5 Effort 1 Disruption 1 ⓘ

Require MFA for all users on all apps: the single highest-value Conditional Access policy.

[Microsoft Learn →](#)

CIS 6.3

CIS 6.4

Policies involved

- *CA001 - Require MFA for all users*: On; delivers it

Why not fully

- Excluded directly (break-glass: assumed, confirm in Setup) (expected)
 - ▼ 1 user
 - Break-glass 01

Guests

- ▼ **In place** **Guests satisfy MFA.** Delivered by *CA001 - Require MFA for all users*. Value 5 Effort 1 Disruption 1 ⓘ

External users get MFA too: their home tenant's hygiene is not your control.

[Microsoft Learn →](#)

CIS 6.3

Policies involved

- *CA001 - Require MFA for all users*: On; delivers it

Here's what needs attention

Identity

- ▼ **Missing** **Security-info registration requires a trusted context.** No policy does this yet. Proposed: *Security-info registration requires a trusted context*. Value 3 Effort 4 Disruption 2 ⓘ

Stop attackers registering their own MFA method on a compromised account.

Proposed name: Security-info registration requires a trusted context

[Microsoft Learn →](#) CIS 6.3

Why not fully

- No enabled policy includes anyone this goal should cover
 - ▼ 4 users
 - Alex Morgan
 - Sam Lee
 - Priya Nair
 - Break-glass 01

[See the step for this in the Roadmap →](#)

▼ **Partly in place** **Legacy protocols blocked** is in report-only via *CA002 - Block legacy authentication* (30 days, 3 would-be failures). **Value 5** **Effort 1** **Disruption 4** ⓘ

Legacy protocols skip MFA entirely; blocking them closes the biggest password-spray door.

Proposed name: Legacy protocols blocked

[Microsoft Learn →](#) CIS 4.8

Policies involved

- *CA002 - Block legacy authentication*: Report-only

Why not fully

- Covered only by a report-only policy, so nothing is enforced yet
 - ▼ 4 users
 - Alex Morgan
 - Sam Lee
 - Priya Nair
 - Jordan Kim

[See the step for this in the Roadmap →](#)

▼ **Missing** **Device-code flow blocked**. No policy does this yet. Proposed: *Device-code flow blocked*. **Value 3** **Effort 1** **Disruption 4** ⓘ

Device-code phishing is a favourite attacker technique; block the flow unless you need it for TVs/kiosks.

Proposed name: Device-code flow blocked

[Microsoft Learn →](#) CIS 4.8

Why not fully

- No enabled policy includes anyone this goal should cover
 - ▼ 5 users
 - Alex Morgan
 - Sam Lee
 - Priya Nair
 - Break-glass 01
 - Jordan Kim

[See the step for this in the Roadmap →](#)

▼ **Missing** **Authentication transfer blocked.** No policy does this yet. Proposed: *Authentication transfer blocked.* Value 3 Effort 1 Disruption 4 ⓘ

Authentication transfer moves a session to another device via QR code: block it unless used.

Proposed name: Authentication transfer blocked

[Microsoft Learn →](#) CIS 4.8

Why not fully

- No enabled policy includes anyone this goal should cover
 - ▼ 5 users
 - Alex Morgan
 - Sam Lee
 - Priya Nair
 - Break-glass 01
 - Jordan Kim

[See the step for this in the Roadmap →](#)

Admins

▼ **Missing** **Admins use phishing-resistant auth.** No policy does this yet. Proposed: *Admins use phishing-resistant auth.* Value 5 Effort 3 Disruption 1 ⓘ

Admins are the crown jewels: require passkeys/FIDO2 or certificate auth, not just push approvals.

Proposed name: Admins use phishing-resistant auth

[Microsoft Learn →](#) CIS 6.5

Policies involved

- CA003 - Admins phishing-resistant: Off

Why not fully

- No enabled policy includes anyone this goal should cover
 - ▼ 1 user
 - Alex Morgan
- A matching policy is switched off: CA003 - Admins phishing-resistant

[See the step for this in the Roadmap →](#)

- ▼ **Missing** **Admin portals need strong auth or are blocked for non-admins.** No policy does this yet. Proposed: *Admin portals need strong auth or are blocked for non-admins.*

Value 4 Effort 3 Disruption 3 ⓘ

Gate the Microsoft admin portals behind strong auth.

Proposed name: Admin portals need strong auth or are blocked for non-admins

[Microsoft Learn →](#) CIS 6.5

Why not fully

- No enabled policy includes anyone this goal should cover
 - ▼ 5 users
 - Alex Morgan
 - Sam Lee
 - Priya Nair
 - Break-glass 01
 - Jordan Kim

[See the step for this in the Roadmap →](#)

Devices

- ▼ **Missing** **Registering or joining a device requires MFA.** No policy does this yet.

Proposed: *Registering or joining a device requires MFA.* Value 3 Effort 2 Disruption 3 ⓘ

Joining or registering a device should itself require MFA.

Proposed name: Registering or joining a device requires MFA

[Microsoft Learn →](#) CIS 6.3

Why not fully

- No enabled policy includes anyone this goal should cover
 - ▼ 5 users
 - Alex Morgan
 - Sam Lee
 - Priya Nair
 - Break-glass 01
 - Jordan Kim

[See the step for this in the Roadmap →](#)

▼ **Missing** **Unknown platforms blocked.** No policy does this yet. Proposed: *Unknown platforms blocked.* **Value 2** **Effort 3** **Disruption 3** ⓘ

If you only support Windows/iOS/Android/macOS, block everything else.

Proposed name: Unknown platforms blocked

[Microsoft Learn →](#) CIS 4.1

Why not fully

- No enabled policy includes anyone this goal should cover
 - ▼ 5 users
 - Alex Morgan
 - Sam Lee
 - Priya Nair
 - Break-glass 01
 - Jordan Kim

[See the step for this in the Roadmap →](#)

Sessions

▼ **Missing** **Admin sessions expire quickly and never persist.** No policy does this yet. Proposed: *Admin sessions expire quickly and never persist.* **Value 4** **Effort 2** **Disruption 1** ⓘ

Short admin sessions that never persist limit what a stolen admin token is worth.

Proposed name: Admin sessions expire quickly and never persist

[Microsoft Learn →](#) CIS 4.3

Policies involved

- CA003 - Admins phishing-resistant: Off

Why not fully

- No enabled policy includes anyone this goal should cover
 - ▼ 1 user
 - Alex Morgan
- A matching policy is switched off: CA003 - Admins phishing-resistant

[See the step for this in the Roadmap →](#)

▼ **Missing** **Unmanaged-device browser sessions are limited.** No policy does this yet.

Proposed: *Unmanaged-device browser sessions are limited.* **Value 3** **Effort 3** **Disruption 2** ⓘ

On unmanaged devices, let people read but limit downloads and session lifetime.

Proposed name: Unmanaged-device browser sessions are limited

[Microsoft Learn →](#) CIS 4.3

Why not fully

- No enabled policy includes anyone this goal should cover
 - ▼ 5 users
 - Alex Morgan
 - Sam Lee
 - Priya Nair
 - Break-glass 01
 - Jordan Kim

[See the step for this in the Roadmap →](#)

▼ **Missing** **Windows desktop sessions require token protection.** No policy does this yet.

Proposed: *Windows desktop sessions require token protection.* **Value 3** **Effort 3** **Disruption 2** ⓘ

Bind Windows sign-in tokens to the device so stolen tokens are useless elsewhere.

Proposed name: Windows desktop sessions require token protection

[Microsoft Learn →](#) CIS 4.3

Why not fully

- No enabled policy includes anyone this goal should cover

- ▼ 5 users
 - Alex Morgan
 - Sam Lee
 - Priya Nair
 - Break-glass 01
 - Jordan Kim

[See the step for this in the Roadmap →](#)

▼ **Missing** **Unmanaged devices cannot download.** No policy does this yet. Proposed: *Unmanaged devices cannot download.* **Value 3** **Effort 4** **Disruption 2** ⓘ

Let unmanaged devices read but not download from SharePoint and Exchange.

Proposed name: Unmanaged devices cannot download

[Microsoft Learn →](#) **CIS 3.3**

Why not fully

- No enabled policy includes anyone this goal should cover
 - ▼ 5 users
 - Alex Morgan
 - Sam Lee
 - Priya Nair
 - Break-glass 01
 - Jordan Kim

[See the step for this in the Roadmap →](#)

▼ **Missing** **Browser sessions never persist for anyone.** No policy does this yet. Proposed: *Browser sessions never persist for anyone.* **Value 2** **Effort 2** **Disruption 2** ⓘ

No 'stay signed in' on shared or unmanaged browsers — sessions end when the browser closes.

Proposed name: Browser sessions never persist for anyone

[Microsoft Learn →](#) **CIS 4.3**

Policies involved

- CA003 - Admins phishing-resistant: Off

Why not fully

- No enabled policy includes anyone this goal should cover

▼ 5 users

- Alex Morgan
- Sam Lee
- Priya Nair
- Break-glass 01
- Jordan Kim

- A matching policy is switched off: CA003 - Admins phishing-resistant

[See the step for this in the Roadmap →](#)

Locations

- ▼ **Missing** **Sign-ins outside allowed countries blocked.** No policy does this yet.

Proposed: *Sign-ins outside allowed countries blocked.* Value 3 Effort 3 Disruption 4 ⓘ

Block sign-ins from countries you never operate in.

Proposed name: Sign-ins outside allowed countries blocked

[Microsoft Learn →](#) CIS 6.3

Why not fully

- No enabled policy includes anyone this goal should cover

▼ 5 users

- Alex Morgan
- Sam Lee
- Priya Nair
- Break-glass 01
- Jordan Kim

[See the step for this in the Roadmap →](#)

Details

- ▼ Does not apply **Office apps require a compliant or joined device:** does not apply (no Intune licence). ⓘ

Office data only on devices you manage (compliant or domain-joined).

[Microsoft Learn →](#) CIS 4.1

▼ Does not apply **Mobile access requires approved or protected apps:** does not apply (no Intune licence). ⓘ

On phones, require approved apps with app-protection policies so company data stays contained.

[Microsoft Learn →](#) CIS 4.1

▼ Needs a licence **Risky sign-ins get MFA or are blocked:** needs a licence tier this tenant does not have (p2). Listed on the Licensing guide, not scored. ⓘ

When Microsoft says a sign-in looks risky, demand MFA or block it automatically.

[Microsoft Learn →](#) CIS 13.1

▼ Needs a licence **High-risk users must change password:** needs a licence tier this tenant does not have (p2). Listed on the Licensing guide, not scored. ⓘ

A likely-compromised account must change its password through a secured flow.

[Microsoft Learn →](#) CIS 13.1

▼ Does not apply **Azure management requires strong auth:** does not apply (no sign-in activity for this workload). ⓘ

The Azure control plane deserves its own strong-auth gate.

[Microsoft Learn →](#) CIS 6.5

▼ Does not apply **Service principals restricted:** does not apply (no Workload Identities Premium licence). ⓘ

Service principals can be scoped and risk-gated too (Workload ID Premium).

[Microsoft Learn →](#) CIS 5.4

▼ Needs a licence **Activating a privileged role asks for MFA every time:** needs a licence tier this tenant does not have (p2). Listed on the Licensing guide, not scored. ⓘ

Elevating to an admin role should always cost a fresh MFA, even mid-session.

[Microsoft Learn →](#)

CIS 5.4

CIS 6.5

▼ Does not apply **Enrolling a device in Intune asks for MFA every time:** does not apply (no Intune licence). ⓘ

Device enrollment is a trust boundary — make it a fresh, interactive sign-in.

[Microsoft Learn →](#)

CIS 4.1

▼ Needs a licence **Medium-risk sign-ins require MFA:** needs a licence tier this tenant does not have (p2). Listed on the Licensing guide, not scored. ⓘ

Medium sign-in risk is common enough to matter; MFA clears most of it without blocking anyone.

[Microsoft Learn →](#)

CIS 6.3

▼ Needs a licence **Medium-risk users must change their password:** needs a licence tier this tenant does not have (p2). Listed on the Licensing guide, not scored. ⓘ

A medium-risk user is likely compromised: force a secure password change.

[Microsoft Learn →](#)

CIS 5.2

CIS 6.3

Policies not in the baseline

Every policy maps to a goal.

Housekeeping

- Naming: no dominant naming convention yet: the plan uses the baseline's

Next: Roadmap